Assessing the Operational and Security Impact of CIS Hardening: A Controlled Pilot Study on Ubuntu Server 24.04 LTS

Christopher Wiggins

A Synthesis Project Presented to the Graduate Faculty
in Partial Fulfillment of the Requirements of the Degree
Master of Science

University of Louisiana at Lafayette
Fall 2026

APPROVED:

Dr. Beenish Chaudhry, Chair
School of Computing and Informatics

Dr. Michael Totaro, Co-chair
School of Computing and Informatics

Dr. Shuvalaxmi Dass
School of Computing and Informatics

Dr. Mehmet Tozal
School of Computing and Informatics

Mary Farmer-Kaiser
Dean of the Graduate School

Abstract

Security hardening changes how a server permits access, executes software, and supports application workflows. For administrators considering changes to an existing server, two practical questions arise: will the changes disrupt normal operation, or will they meaningfully restrict a relevant attack? This Synthesis Project presents a proposed pilot study of the operational effects of one recommendation from the Center for Internet Security (CIS) Ubuntu Linux Benchmark. The study will compare a working Ubuntu Server 24.04 LTS web application with an otherwise equivalent configuration in which the selected recommendation is applied. A repeatable application workflow will measure functional impact, while a separately defined security test will measure weather a specific attacker objective remains achievable. Configuration evidence, application output, and system logs will support interpretation of the observed differences. The intended contribution is a reproducible case study connecting a hardening change to its operational consequences and scenario-specific security benefit. Experimental results have not yet been collected.

Table of Contents

Abstract iii

Preface 1

Introduction 1

1 Purpose and Research Questions 2

2 Scope and Experimental Environment 3

3 Proposed Methodology 3

3.1 Selection of the Recommendation and Security Scenario 3

3.2 Experimental Conditions 4

3.3 Baseline Preparation 5

3.4 Trial Procedure 5

3.5 Outcome Measures 6

3.6 Interpretation and Recovery 7

4 Related Work - To Be Developed 7

5 Results - Pending Experimentation 8

6 Discussion and Limitations 8

7 Conclusion - Pending Results 8

8 References 9

Biographical Sketch 9

Preface

Introduction

Administrators maintaining an existing server must preserve the services that users depend on while reducing opportunities for misuse. Configuration changes can affect both objectives. A restriction that removes an unnecessary capability may reduce exposure without disrupting the application. The same restriction may interfere with a different application that legitimately depends on that capability. Evaluating a hardening change therefore requires an explicit description of the server's intended function and the unwanted behavior the change is expected to restrict.

The Center for Internet Security publishes consensus-based secure configuration guidance through its CIS Benchmarks. CIS distinguishes between Level 1 guidance, intended to preserve usability while reducing attack surface, and Level 2 guidance for environments with stronger security requirements. CIS also recommends testing benchmark guidance before deployment to determine its impact [1]. These objectives motivate an empirical examination of how an individual recommendation behaves in a defined server environment.

A configuration assessment and an attack experiment answer different questions. An assessment can establish whether a setting matches a recommendation. An experiment can establish whether a particular action succeeds under the tested conditions. This study will record configuration state alongside legitimate workload outcomes and security-test outcomes. A successful configuration check alone will not be treated as proof that an attacker objective has been prevented.

The project addresses two practical questions: "Will hardening my existing server break its intended function?" and "Is the security benefit worth the operational cost?" The initial experiment will address a limited, testable version of these questions. It will examine one rec-

[1] Center for Internet Security. "CIS Benchmarks FAQ." Accessed October 7, 2026. `https://www.cisecurity.org/cis-benchmarks/cis-benchmarks-faq`

ommendation, one application workflow, and one attacker objective. Its findings will describe that combination rather than establish the overall effectiveness of the entire CIS Benchmark.

1 Purpose and Research Questions

The purpose of this study is to evaluate the effect of a selected CIS hardening recommendation on both legitimate server operation and a defined attack scenario. The initial pilot will establish a repeatable method that can later be applied to additional recommendations without changing the meaning of the measured outcomes.

The study will address the following research questions:

1. **RQ1 - Operational impact:** How does applying the selected recommendation affect successful completion of the server's intended application workflow?
2. **RQ2 - Security impact:** How does applying the selected recommendation affect the ability to achieve the defined attacker objective under the same starting conditions?
3. **RQ3 - Trade-off:** What operational disruption or adaptation, if any, accompanies the observed security benefit in this workload?

The working expectation is that the selected recommendation will restrict a specific unwanted behavior. Whether that restriction also affects legitimate operation will depend on the application's reliance on the capability being restricted. Before data collection, this expectation will be converted into a control-specific hypothesis identifying the exact setting, predicted mechanism, and observable outcomes. No hypothesis about a particular recommendation is asserted in this draft because that recommendation has not yet been selected.

2 Scope and Experimental Environment

The pilot will use Ubuntu Server 24.04 LTS hosted in Proxmox. The proposed target VM, `baseline-web`, will have two virtual CPUs, 4 GB of memory, and a 40 GB virtual disk. A separate test VM will act as the workload client and security-test origin. The environment will be isolated from production services and will use synthetic files and test accounts.

The proposed workload is a small file-upload, processing, and download application. Nginx will provide the HTTP endpoint, and a Flask application will run through Gunicorn under systemd, with Gunicorn listening on localhost. SSH will provide administrative access. Supporting software will include Python 3 and virtual-environment support, curl, jq, rsync, and the QEMU guest agent. Exact package versions, application code, service configuration, and filesystem layout will be recorded when the baseline is built.

The application will have a documented processing operation with a known expected output. A successful legitimate transaction will require submitting a fixed input file, completing the processing operation, and retrieving the correct result. HTTP availability alone will not establish that the workflow functions correctly.

The pilot will not initially apply an entire Level 2 profile. The treatment system will be described as having the selected recommendation applied; it will not be described as fully CIS-compliant. Additional controls, applications, operating systems, and attack scenarios fall outside this first experiment.

3 Proposed Methodology

3.1 Selection of the Recommendation and Security Scenario

Before testing, the study will record the exact CIS Benchmark title, version, recommendation identifier, recommendation title, and associated profile. The recommendation must be applicable to the target and have a plausible relationship to a measurable unwanted action. The appli-

cation will be defined and validated before treatment is applied so that observed breakage can be assessed against a pre-existing functional requirement.

The security scenario will specify the actor's starting privileges, access path, prerequisite conditions, attempted action, and success criterion. Remote unauthenticated access and execution as an already-compromised service account represent different starting conditions and will not be treated as interchangeable. If the experiment assumes an initial compromise, that assumption will be stated explicitly; the test will then measure restriction of a subsequent action rather than prevention of the initial compromise.

The security test must demonstrate the attacker objective in the baseline. If it cannot, a failure in the treatment condition will not establish a hardening benefit. Failed prerequisites, tooling errors, and unrelated connectivity failures will be recorded separately from prevention attributable to the selected setting.

3.2 Experimental Conditions

Two conditions will be derived from the same validated workload snapshot:

- **B - Baseline:** The working server before the selected recommendation is applied. Its default protections and relevant configuration will be recorded; "baseline" does not imply that all security features are disabled.
- **H - Treatment:** A clone of B with only the selected recommendation and its necessary implementation steps applied. All resulting differences will be documented.

The independent variable is whether the selected recommendation is applied. The primary dependent variables are legitimate workflow completion and attacker-objective attainment. Package versions, application code, input files, VM resources, credentials, and test commands will be held constant across the comparison.

If the baseline already satisfies the recommendation, a meaningful contrast must be established and documented before testing. Likewise, if applying the recommendation requires

several configuration changes, the treatment will be identified as that set of changes; effects will not be attributed to an individual component without further experimentation.

3.3 Baseline Preparation

The operating system and required packages will be installed and their versions recorded. Snapshot `01-os-ready` will preserve the operating-system starting point. The application will then be configured and its expected behavior validated. Snapshot `02-workload-ready` will preserve the working baseline from which experimental conditions are derived.
The baseline record will include service status, listening sockets, relevant permissions, mount options, application configuration, and test inputs. Package updates and unrelated configuration changes will be excluded during a comparison. If a required environmental change occurs, both conditions will be rebuilt or revalidated from an equivalent starting point.

3.4 Trial Procedure

Each trial will use the following sequence:

1. Restore the appropriate condition's clean snapshot and wait for the defined readiness checks to pass.
2. Verify the effective setting under study and record the condition and trial identifiers.
3. Execute the legitimate workflow with the fixed input and compare the output with the expected result.
4. Execute the predefined security test from its documented starting state and collect independent evidence of whether the attacker objective was achieved.
5. Preserve test output, relevant logs, configuration evidence, and any unexpected behavior before restoring the VM.

The legitimate workflow will precede the security test so that attack-induced changes cannot account for an earlier functionality failure. Any preparation needed for the security test will be specified and applied consistently. The next trial will begin from a clean snapshot rather than from the previous trial's final state.

As an initial protocol choice, five valid trials per condition are proposed to check repeatability. Baseline and treatment runs will be alternated to reduce simple order effects. Exclusion criteria will be fixed before collection; excluded runs and their reasons will remain in the experiment record. Repeated trials on one application and VM design will not be treated as independent samples of the wider server population.

3.5 Outcome Measures

The primary operational outcome will be end-to-end completion of the legitimate workflow with correct output. Secondary observations will include elapsed time, error messages, service failures, and manual intervention. Timing measurements will be descriptive in this pilot unless a separate performance protocol is established.

The primary security outcome will be whether the predefined attacker objective is achieved. The evidence must show the relevant effect on the target, rather than rely only on a test tool's success or failure message. Outcomes will distinguish objective achieved, objective prevented with supporting evidence, and inconclusive execution.

For descriptive reporting, the functionality success fraction for condition c will be:

$$F_c = \frac{validtrialswithcorrectworkflowcompletion}{validfunctionalitytrials}. \tag{1}$$

The attacker-objective success fraction will be:

$$A_c = \frac{validtrialsachievingtheattackerobjective}{validsecuritytrials}. \tag{2}$$

Raw counts and inconclusive runs will accompany these fractions. A reduction in attacker

success from B to H will support a benefit for the tested scenario, provided that the control mechanism and experimental validity checks support that interpretation. It will not establish a general probability of real-world compromise.

3.6 Interpretation and Recovery

Results will be interpreted across both dimensions. Preserved functionality with a prevented attacker objective would support applying the recommendation for this workload and threat scenario. A prevented objective accompanied by legitimate workflow failure would demonstrate an operational trade-off requiring further investigation. Unchanged attacker success would show that the tested recommendation did not prevent that objective under the stated conditions, rather than show that it has no security value in other circumstances.

If functionality fails after treatment, a separate diagnostic rollback will test whether removing the change restores the workflow. Any application adaptation will be recorded as a new condition rather than silently incorporated into H. This preserves the distinction between the immediate effect on an existing server and the effort required to operate that server with the recommendation retained.

The study will report measured consequences and any adaptation effort separately. A universal judgment that hardening is "worth it" would require organizational risk and cost assumptions beyond this pilot.

4 Related Work - To Be Developed

The literature review will examine empirical studies of secure configuration, compatibility effects of hardening, and experimental measurement of attack outcomes. It will distinguish studies of benchmark conformance from studies that measure legitimate application behavior and adversarial outcomes together. Claims of novelty or of a research gap will be deferred until that review is completed.

5 Results - Pending Experimentation

No experimental results are available. This section will report the selected recommendation, verified configuration differences, valid and excluded trial counts, functionality outcomes, security outcomes, and evidence supporting causal interpretation. Unexpected findings and unsuccessful hypotheses will be retained.

6 Discussion and Limitations

This pilot will examine one application, one operating-system release, one recommendation, and one security scenario in a virtualized environment. Its results will therefore be bounded by those conditions. They will not establish the effectiveness of an entire benchmark or predict compatibility with unrelated applications.

The demonstration workload may omit dependencies present in production systems. Host contention may affect observed timing, and repeated snapshot trials may reproduce behavior without establishing generalizability. Other protections already active in the baseline may interact with the selected recommendation. Recording the effective configuration and verifying baseline attacker success will help identify these issues but will not eliminate all possible interactions.

The expected contribution is a reproducible account of a specific hardening decision: what changed, what behavior continued or failed, what attacker objective remained possible or was restricted, and what evidence supports those conclusions.

7 Conclusion - Pending Results

A final conclusion will be written after testing. It will answer each research question using the observed results and identify the conditions under which those answers apply.

8 References

Biographical Sketch

Christopher Wiggins graduated from the University of Louisiana at Lafayette in 2021 with a Bachelor of Science in Informatics, with a concentration in Systems Adaministration. He then worked as a support analyst for TEKsystems in 2021-2022, and T. Baker Smith in 2022-2023. He returned to the University of Louisana at Lafayette in 2023 as a Network Analyst and entered the master's degree program in Informatics in 2024. His research in that program has centered on Linux Server Hardening and Cryptography. He graduated in the Fall of 2026 with a Master of Science in Informatics degree with a concentration in Cyber Security.